دليل الهندسة الاجتماعية والاستخبارات مفتوحة المصدر (OSINT & Social Engineering)

شرح وتطبيق بالدارجة المغربية: كيفاش كتتجمع المعلومات، كيفاش كيربطها المهاجم، وكيفاش كنستعملو أدوات **OSINT** فـ **Kali Linux** باش نكشفو شنو باين على الشركة وننقصو هاد التعرض.

تنبيه أخلاقي وقانوني — Morocco Cyber & AI Lab (TH3HUBRIS): جميع التطبيقات والأوامر المشروحة فهاد الدليل مخصصة للتطبيق فقط على **Assets** ديالك أو داخل **Lab / Scope** عندك عليه الإذن القانوني. الهدف هو تغطية المسار الكامل من فهم **Social Engineering** حتى لأدوات **OSINT** والتطبيق العملي لحماية معطيات الشركة.

01. الهندسة الاجتماعية (Social Engineering): كيفاش كيبدأ الهجوم قبل ما يبدا الاختراق

01 // SOCIAL ENGINEERING

الهندسة الاجتماعية (Social Engineering) ببساطة هي ملي شي واحد كيلعب على الثقة ديالك باش ياخذ منك معلومة، يخليك تدير **Action**، ولا يجرك لخطوة ما كنتيش غادي تديرها بوحدك. بزاف ديال المرات الهاكر ما كيحتاجش يبدا بثغرة تقنية؛ كيبدا غير بواحد المعلومة صغيرة، ومن بعد كيجمع عليها معلومات خرين حتى كيبني صورة واضحة على الشخص ولا الشركة.

المعلومة (شنو كيقلب عليه فالأول؟)	علاش كتهمو في بناء الهجوم؟
الاسم والمنصب	باش يعرف شكون يقدر ينتحل الصفة ديالو وشكون عندو صلاحيات داخل الشركة.
الإيميل ورقم الهاتف	باش يربط الحسابات مع بعضياتها ويعرف قنوات التواصل المباشرة.
أسماء المسؤولين والموردين	باش القصة أو السيناريو ديالو يبان طبيعي وماشي عشوائي.
الـ Usernames	باش يشوف واش نفس الاسم مستعمل فمواقع ومنصات خرين.
صور المكتب والوثائق	ممكن يبان فيهم **Badge**، أسماء شاشة، **Software**، **Wi-Fi**، ولا **Metadata**.
الدومينات والـ Subdomains	باش يعرف الخدمات والبنية اللي باينة للعالم الخارجي.

كيفاش كتولي المعلومة الصغيرة خطيرة؟ مثلا لقى اسم موظف، عرف أنه خدام فالمحاسبة، لقى فـ **LinkedIn** اسم المدير، ومن منشور قديم عرف اسم واحد المورد. كل وحدة بوحدها ماشي سر، ولكن منين كيتجمعو كيولي عندو **Context** كافي باش محاولة الانتحال تبان معقولة. هنا كيبان علاش **OSINT** مهم فالدفاع: خاصك تشوف شنو يقدر يشوف عليك شي واحد من برا قبل ما يستعملو ضدك.



الشكل 1: تسلسل بناء الهجوم من جمع المعلومات العامة (**01**) إلى الانتحال (**04**)، ودور المراجعة الدفاعية (**05**).

02. OSINT: شنو باين عليك فالنت بلا ما تحس

`02 // PASSIVE vs ACTIVE OSINT`

OSINT (Open Source Intelligence) هي المعلومات اللي نقدرو نلقاوها من مصادر مفتوحة: مواقع، محركات البحث، **Certificates**، **DNS**، حسابات عامة، ملفات منشورة، **Metadata**، **GitHub** وغيرهم. فخدمة الـ **Cyber Security** كنستعملوها باش نديرو نفس النظرة اللي يقدر يديرها مهاجم من برا، ولكن على الشركة ديالنا ولا داخل **Scope** واضح. فالأمثلة التطبيقية اللي فيها دومين، غادي نستعملو دومين تدريبي بحال **`mcalab.ma`** أو أي دومين **Training** عندك عليه الإذن:

- **الجمع السلبي (Passive OSINT):** كتقلب فمصادر عامة بلا ما تدير **Scan** مباشر على السيرفر (مثال: **Certificate**، **Google Transparency**، و**Public profiles**).
- **الجمع النشط (Active OSINT):** كتتاصل مباشرة بخدمة ولا **Asset** داخل نطاق الاختبار (مثال: **DNS query**، زيارة **Endpoint**، أو **Scan** مصرح به).

03. Fingerprint.to: قلب على الـ Username، الـ Email والرقم

`03 // FINGERPRINT.TO AUDIT`

موقع **Fingerprint.to** مفيد ملي بغيتي تشوف واش واحد **Identifier** باين فبلايص خرين فالنت. كتدخل **Username** ولا **Email** ولا **Phone**، وكتراجع النتائج اللي مرتبطة به. اللي كيهمنا فـ **Security Audit** هو **الربط**: واش الإيميل المهني خارج فموقع ما عندو حتى علاقة بالخدمة؟ واش نفس **Username** ديال الخدمة هو نفسه المستعمل فحسابات شخصية؟

1. **تحديد المعرف:** حدد شنو باغي تقلب عليه: **Username** مهني، **Email** ديال الشركة، ولا رقم هاتف رسمي.
2. **البحث الأولي:** من الـ **Dashboard** دير **Search** وخلي النتائج قدامك وحدة بوحدة.
3. **التحقق اليدوي:** ما تعتمدش على الاسم بوحدو؛ شوف الصورة، الـ **Bio**، المدينة، الروابط وأي **Clue** باش تتأكد واش هو نفس الحساب.
4. **تصنيف النتيجة:** قسم النتيجة إلى حساب مهني، حساب شخصي مربوط بالخدمة، حساب قديم، ولا نتيجة ماشي ديال نفس الشخص.
5. **التوثيق:** سجل غير الحاجة اللي عندها قيمة فالتدقيق: الرابط، شنو بان، وشنو الخطر اللي كيزيد.

شنو قلبنا (Identifier)	شنو لقينا فالنتائج	شنو فهمنا (الأثر الأمني)
`support@company.tld`	**Profile** عام فيه اسم شخص كامل	العنوان اللي خاصو يبقى **Role account** ولى مربوط بموظف محدد.
`brand_handle`	نفس **Username** فمنتدى قديم	كاين ربط مباشر بين البراند وحساب قديم غير مراقب.
رقم الشركة الرسمي	**Directory** عام كيبين اسم موظف	الرقم الرسمي كيعطي معلومة زيادة على الشخص اللي كيسيرو.

04. Maltego: من المعلومات المفرقة لواحد Graph واضح

`04 // MALTEGO GRAPHING`

أداة **Maltego** كتساعدك ملي كتكون عندك معلومات كثيرة ومبقيتيش باغي تبقى تجمعها فـ **Notepad**. كتدخل **Entity** بحال **Domain** ولا **Email**، ومن بعد كتزيد العلاقات اللي لقيتي حتى كيبان قدامك **Graph** كيوضح شنو مربوط بشنو، وفين كاين الربط اللي ما كانش خاصو يكون باين.

التثبيت والتشغيل // KALI LINUX

```
sudo apt update && sudo apt install -y maltego maltego
```

البداية (Entity)	شنو نربطو بها (Transforms)	شنو كنقلبو عليه فـ Maltego Graph
Domain	`DNS / Certificates / URLs`	**Subdomains**، أسماء **Services** قدام، و**Hosts** منسية.
Email	`Public mentions / Profiles`	فين خارج الإيميل فالنت وشكون الموظف المربوط به.
Document	`Metadata / Author / Links`	اسم **User** داخلي، **Software** مستعمل، وطريقة **Naming**.
Username	`Social / Code platforms`	واش كاين **Reuse** لنفس المعرف بين الخدمة والحياة الشخصية.

ملاحظة عملية: فالخدمة الحقيقية، ما تحتاجش تشغل كل **Transform**. كتبدا بسؤال واضح مثلا: **"شنو هي الـ Subdomains اللي باينة من برا؟"** وكتخدم غير على هاد السؤال حتى توصل لجواب.

05. theHarvester: جمع Emails و Hosts من مصادر Public

`05 // THEHARVESTER RECON`

أداة **theHarvester** من الأدوات اللي كتسهل عليك أول **Recon** على دومين؛ كتجمع **Emails** و **Hosts** ومعلومات من مصادر مختلفة، وكتقدر تبدا بمصادر **Passive** (بحال **Certificate Transparency**) باش تشوف الصورة بلا **Scan** مباشر. منين يخرج لك **Host** ولا **Subdomain**، قارن النتيجة مع الـ **Asset Inventory** ديال الشركة: واش معروف؟ واش باقي خدام؟ واش داخل **Monitoring**؟

التثبيت، البحث عبر الشهادات، وحفظ النتيجة // KALI LINUX

```
sudo apt update && sudo apt install -y theharvester theHarvester -h theHarvester -d mcalab.ma
-b crtsh,certspotter theHarvester -d mcalab.ma -b crtsh,certspotter -f mcalab-osint
```

06. SpiderFoot: جمع بزاف ديال OSINT فبلاصة وحدة

`06 // SPIDERFOOT AUTOMATION`

أداة **SpiderFoot** عندها **Modules** كثيرة وكتعاون ملي بغيتي **Scan** منظم بدل ما تبقى داير عشرات الأدوات بوحدهم. كتدخل **Target** داخل الـ **Scope**، كتحدد النوع ديال المعلومات اللي باغي، وكتخلي الأداة تجمع وتربط النتائج. فالـ **Audit** مزيان تبدا صغير (**Domain** واحد ومجموعة **Modules** مفهومة) ومن بعد توسع غير إلا بقا عندك سؤال ما تجاوبش:

- **شنو نخلي فالأول؟** نركزو على: **Emails**، **Public web mentions**، **DNS & Certificates** اللي باينين فمصادر عامة، **Metadata & Public files**، و**Reputation / Breach indicators** (إلا كان عندك الحق تستعمل المصدر).

التثبيت وتشغيل الواجهة المحلية (127.0.0.1:5001) // KALI LINUX

```
sudo apt update && sudo apt install -y spiderfoot spiderfoot -h python3 sf.py -l
127.0.0.1:5001
```

07. Recon-ng: خدم كل تحقيق فـ Workspace بوحدو

`07 // RECON-NG WORKSPACES`

إطار **Recon-ng** مناسب ملي بغيتي تخدم بطريقة مرتبة؛ كل شركة ولا كل **Test** تقدر تدير ليه **Workspace** بوحدو، وتخلي الـ **Modules** والنتائج مجموعين فبلاصة وحدة. قبل ما تستعمل أي **Module**، دير `info` وشوف شنو باغي كـ **Inputs** وشنو المصدر اللي كيستعمل (حيث بعض الـ **Modules** كيحتاجو **API keys**).

التثبيت وإنشاء Workspace خاص بالتدقيق // KALI LINUX

```
sudo apt update && sudo apt install -y recon-ng recon-ng [recon-ng][default] > workspaces
create mcalab_audit [recon-ng][mcalab_audit] > workspaces list [recon-ng][mcalab_audit] >
marketplace search [recon-ng][mcalab_audit] > modules search
```

08. Sherlock: واش نفس Username داير دورة فالنت؟ 08 // SHERLOCK USERNAME HUNT

إعادة استعمال نفس **Username** كتسهل الربط بين الحساب المهني والحسابات الشخصية. أداة **Sherlock** كتقلب على **Username** فعدد كبير ديال المواقع وكتعطيك فين لقات نفس الاسم. تذكر أن النتيجة ماشي دليل بوحدها أن الحساب ديال نفس الشخص؛ كتحتاج تقارن الـ **Bio**، الصورة، الروابط، واللغة قبل ما تربط الحسابات مع بعضها.

KALI LINUX // البحث عن Username وحفظ النتيجة فملف نصي

```
sudo apt update && sudo apt install -y sherlock sherlock username_here sherlock brand_handle
--output sherlock-brand.txt
```

09. ExifTool: شنو مخبي الملف من الداخل (Metadata) 09 // EXIFTOOL METADATA

الصورة ولا ملف **PDF** يقدر يبان عادي، ولكن **Metadata** ديالو ممكن يكون فيها اسم البرنامج، **Author** (اسم الموظف)، تاريخ الإنشاء، إحداثيات **GPS** فبعض الصور، **Device model**، ولا مسارات **Paths** داخلية ديال الجهاز. أداة **ExifTool** كتعطيك هاد التفاصيل بسرعة، وكتخليك تنظف النسخة اللي غادي تنشر للعموم.

KALI LINUX // قراءة Metadata ومسحها من نسخة مخصصة للنشر

```
sudo apt update && sudo apt install -y libimage-exiftool-perl exiftool photo.jpg exiftool
report.pdf find ./public-files -type f -print0 | xargs -0 -n1 exiftool cp photo.jpg photo-
public.jpg && exiftool -all= photo-public.jpg
```

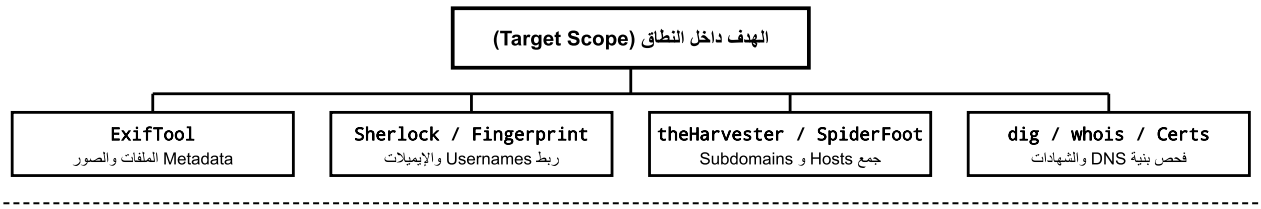
10. DNS و WHOIS و Certificate Transparency: البنية اللي باينة من برا 10 // DNS, WHOIS & TLS CERTS

حتى بلا **Scanner**، سجلات **DNS** و **Certificates** يقدرو يعطيوك فكرة واضحة على الخدمات اللي الشركة كتستعمل. هنا كتقارن شنو **Public** مع شنو عندك مسجل داخليا:

KALI LINUX // فحص سجلات DNS ومعلومات WHOIS

```
dig mcalab.ma A dig mcalab.ma MX dig mcalab.ma TXT dig _dmarc.mcalab.ma TXT nslookup
mcalab.ma whois mcalab.ma
```

- **سجلات MX و TXT و DMARC:** سجل **MX** كيبين شكون كيسير البريد؛ سجل **TXT** كيبين إعدادات **SPF** وأي **Verifications** باينين؛ وسجل **_dmarc** كيبين واش كاين وشنو هي الـ **Policy** المطبقة.
- **Certificates و WHOIS:** شهادات **TLS** كتبين أسماء **Subdomains** اللي خرجات فالشهادات، بينما **WHOIS** كيبين معلومات التسجيل اللي باقية **Public** حسب الـ **Registry** والـ **Privacy**.



الشكل 2: تكامل أدوات **OSINT** في **Kali Linux** لتغطية البنية التقنية، الحسابات، والملفات المنشورة.

11. Breach Exposure: واش Email ديال الشركة سبق خرج فتسريب؟ 11 // BREACH EXPOSURE AUDIT

فهاد الجزء ما كنقلبوش على **Passwords** ديال الناس؛ اللي كيهمنا هو نعرفو واش حساب مهني ظهر فـ **Breach** معروف، فاش كان داك التسريب، وشنو خاص يتراجع داخل الشركة من بعد. وجود **Email** فـ **Breach** قديم ما كيعنيش أوتوماتيكيا أن كلمة السر الحالية مسروقة، ولكن كيعني أن هاد الهوية ولات معروفة وممكن تتستعمل فمحاولات انتحال أو **Credential Stuffing** إلا كان **Password Reuse**:

1. استعمل خدمة رسمية كتسمح للشركة تثبت ملكية الدومين ولا تراجع البريد ديالها بشكل قانوني.
2. خرج غير الحسابات التابعة للشركة ولا الأشخاص اللي داخل الـ **Scope**.
3. سجل اسم الـ **Breach**، التاريخ، والإيميل المتأثر — **ما تجمعش Password مسروق نهائيا**.
4. راجع واش الحساب تبدلات كلمة السر ديالو، واش **MFA** شاعل، وواش كاين **Password Reuse** فخدمات الشركة.
5. من بعد الإصلاح، خليه داخل **Monitoring** باش أي ظهور جديد يتشاف بكري.

12. تطبيق كامل: دير خريطة ديال المعلومات اللي باينة على الشركة 12 // FULL OSINT WORKFLOW

دابا نجمعو الأدوات كاملة فواحد السيناريو عملي من 5 مراحل، بافتراض بلي عندك دومين الشركة وحسابات رسمية وباغي تعرف شنو يقدر يشوف واحد من برا:

- **المرحلة 1 و 2 (الدومين، البريد، والـ Certificates):** فحص سجلات **DNS** متبوع بجمع الـ **Hosts** عبر الشهادات.
- **المرحلة 3 (Usernames وحسابات عامة):** استعمل **Fingerprint.to** على الـ **Emails** والـ **Usernames** الرسمية، و **Sherlock** على أسماء البراند أو الـ **Handles** (أي **Match** خاصو يتراجع يدويا قبل التسجيل).
- **المرحلة 4 و 5 (الملفات المنشورة وجمع كلشي فـ Maltego):** فحص **Metadata** ديال الملفات العامة، ثم إدخال **Entity Domain** فـ **Maltego** وإضافة الـ **Emails** والـ **Usernames** والـ **Documents** المؤكدة باش يبان لك الـ **Graph** الكامل للروابط.

أوامر التطبيق المتسلسل (المراحل 1، 2، و 4) // KALI LINUX

```
# Stage 1: Domain & Mail DNS dig mcalab.ma A && dig mcalab.ma MX && dig mcalab.ma TXT && dig
_dmarc.mcalab.ma TXT # Stage 2: Certificates & Hosts theHarvester -d mcalab.ma -b
crtsh,certspotter -f stage2-hosts # Stage 4: Public Files Metadata mkdir -p audit/public-
files && exiftool audit/public-files/*
```

13. كيفاش كيتستعمل هاد الـ OSINT فـ Social Engineering 13 // OSINT TO SOCIAL ENGINEERING

هنا خاصنا نفهمو الربط بين المعلومات والخداع. ما محتاجينش نبنيو رسالة تصيد ولا صفحة مزورة؛ غير كنحللو شنو كيعطي للمهاجم المصداقية (مثلا معرفة اسم مسؤول الحسابات + اسم مورد حقيقي + وقت غياب المدير من منشور عام = 3 قطع ديال **Context** كافية للهجوم):

المعلومة اللي لقا المهاجم	شنو كتزيد للمهاجم؟	شنو كنستنتجو دفاعيا (Exposure Review)؟
اسم المدير + منصبو	يقدر ينتحل السلطة داخل الشركة.	ما نخليوش كل الهيكلة والتفاصيل الحساسة **Public** بلا سبب.
اسم مورد حقيقي	كيخلي قصة الفاتورة ولا الطلب تبان طبيعية.	أي تغيير مالي أو بنكي خاصو **Verification** مستقل.
رقم موظف شخصي	كيعطي قناة تواصل مباشرة خارج الرقابة.	نفصلو **Contact** المهني على الشخصي ملي ما كاينش سبب للنشر.
نفس Username فخدمات كثيرة	كيجمع بروفايل أكبر على الشخص وعاداتو.	نفرقو الـ **Handles** المهنية على الشخصية بشكل تام.
Metadata فيها User أو Software	كتزيد تفاصيل تقنية دقيقة على البيئة الداخلية.	ننظفو جميع الملفات والوثائق قبل النشر للعموم.

14. كيفاش نقصو المعلومات اللي باينة من برا — تطبيق على الـ Findings

14 // REMEDIATION & HARDENING

من بعد ما كتجمع النتائج، كتخدم **Finding** بـ **Finding**. الهدف ماشي هو "نخبيو كلشي"، ولكن أي معلومة ما عندها حتى فائدة تبقى **Public** وكتزيد الخطر، كنشوفو كيفاش نحيدوها ولا نفصلوها، ومن بعد كنعاودو نفس البحث باش نتأكدو واش الـ **Finding** تحيد فعلا ولا باقي كيبان من مصدر آخر:

اللي لقيتي (Finding)	التطبيق اللي كيتدار (Remediation Action)
Email شخصي ظاهر مع المنصب	يتبدل فالموقع بـ **Role address** بحال `support@` ولا `contact@` إلا كان مناسب.
نفس Username مهني وشخصي	يتبدل الـ **Handle** المهني أو الشخصي باش ما يبقاش الربط مباشر بيناتهم.
حساب قديم فيه معلومات على الخدمة	يتنظف الـ **Bio**، الصور والمعلومات القديمة، أو يتحيد الحساب إلا ما بقاش محتاج.
ملف PDF فيه Author / Paths	تنظف نسخة النشر بـ **ExifTool** ويتراجع الملف من جديد قبل رفعه للموقع.
Subdomain قديم أو منسي	يتأكد المالك ديالو: يا إما يبقى مراقب ومحدث، يا إما يتسد بالطريقة الصحيحة.
رقم موظف شخصي فدليل عام	يتبدل برقم خدمة / رقم رسمي إلى ما كانش سبب يخلي الرقم الشخصي **Public**.

KALI LINUX // تطبيق سريع لتنظيف الملفات وإعادة فحص الدومين (Re-test)

```
exiftool document.pdf && cp document.pdf document-public.pdf && exiftool -all= document-public.pdf dig mcalab.ma TXT && dig _dmarc.mcalab.ma TXT theHarvester -d mcalab.ma -b crtsh,certspotter
```

15. كيف نكتب النتيجة باش تبقى مفهومة وقابلة للتطبيق

15 // REPORTING TEMPLATE

فآخر الـ **Audit** ما تحتاجش تقرير عامر كلام إنشائي. كل **Finding** خاصو يكون قصير، مباشر، وواضح: شنو لقيت، فين لقيتو، كيفاش تأكدت، وشنو خاص يتبدل من بعد:

الخانة (Field)	مثال تطبيقي لتوثيق النتيجة في التقرير
Title	`Public employee email linked to personal profile`
Asset	`employee@mcalab.ma`
Evidence	الرابط المباشر + تاريخ المراجعة + **Screenshot** عند الحاجة.
شنو بان (Observation)	**Email** مهني رسمي مربوط ببروفايل شخصي عام فمواقع التواصل.
علاش مهم (Risk Impact)	كيزيد **Context** دقيق على الموظف وكيعاون المهاجم فعمليات الانتحال (**Spear Phishing**).
شنو تدار (Remediation)	تحيد الإيميل المهني من البروفايل الشخصي وتفصل الحساب المهني على الشخصي.
Re-test (إعادة الفحص)	تعاود نفس البحث عبر أدوات **OSINT** وتتأكد واش النتيجة بقات ولا تحيدات نهائيا.

خلاصة الدليل التطبيقي (OSINT & Social Engineering): إن التحكم في أدوات **OSINT** داخل بيئة **Kali Linux** (من **Maltego** و **theHarvester** و **SpiderFoot** إلى **Sherlock** و **ExifTool**) يمنح فرق الدفاع القدرة على كشف البصمة الرقمية للمؤسسة وتقليص مساحة الهجوم قبل استغلالها في عمليات الهندسة الاجتماعية. — **إعداد: TH3HUBRIS (Morocco Cyber & AI Lab)**.